

SARVAR TOLIPOV

KIBERXAVFSIZLIK MUTAXASSISI • PENETRATION TESTER

thestrak118@gmail.com | linkedin.com/in/sarvar-tolipov-436aba399 | github.com/thestrak118-web | sarvar-portfoli.vercel.app | t.me/tolipovsec | +998 50 522 11 91 | Toshkent, O'zbekiston

QISQACHA MA'LUMOT

Production muhitidagi **10+ real loyihada** tashqi penetration testing o'tkazgan kiberxavfsizlik mutaxassisi. Topilmalar orasida **CVSS 9.8 (Critical)** darajali, autentifikatsiyasiz to'liq platforma egallash zanjirlari bor — barchasi PoC bilan jonli isbotlangan va CVSS 3.1 bo'yicha professional hisobotda hujjatlashtirilgan. QA yo'nalishida junior tajriba: **20+ yirik sayt/dashboard, 90+ reliz**. HTB CPTS, SWES va CDSA kurslari 100% yakunlangan — imtihonlar kutilmoqda; CompTIA Security+ ga tayyorgarlik ketmoqda.

ISH TAJRIBASI

ASOS IT — QA Engineer & Penetration Tester | *Aprel 2026 - hozirgacha*

Kiberxavfsizlik / penetration testing

- Production infratuzilmalarida **10+ to'liq qamrovli tashqi pentest** (black-box → authenticated) PTES / OWASP WSTG bo'yicha bajarildi — yozma ruxsat, ROE va vaqt muhri qaydlar bilan.
- SaaS platformasi + AWS EC2 audit: **3 Critical (CVSS 9.1–9.8)**, 4 Medium va 6 Info topilma aniqlandi. Autentifikatsiyasiz to'liq platforma egallash zanjiri jonli isbotlandi: catch-all route orqali manba kod va .env oshkorligi → JWT imzo kalitini tiklash → SuperAdmin token yasash → himoyalangan admin endpointlariga kirish.
- Shu auditda butun ma'lumotlar bazasini autentifikatsiyasiz yuklab olish (9.1), qayta ishlatilgan JWT sekreti (9.1), auth tokenning URL'da uzatilishi, IDOR sirti va jonli API kalitlari oshkorligi aniqlandi; biznes ta'siri baholanib, ustuvorlashtirilgan tuzatish rejasi taqdim etildi.
- Ta'lim/qabul platformasi: OTP tasdiqlashni chetlab o'tish orqali **account takeover (CVSS 9.8)** — faqat telefon raqami bilan istalgan akkaunt egallanardi; shuningdek doimiy kirish beruvchi token sizishi, shaxsni tasdiqlovchi hujjatlarga (pasport, diplom) nazoratsiz kirish, parol xeshlarining oshkorligi va user enumeration aniqlandi.
- SQLi, IDOR, path traversal/LFI, SSRF, JWT alg-confusion, command injection va file-upload → RCE tizimli sinalib **rad etildi** va hisobotda *negative results* sifatida hujjatlashtirildi. Har bir engagement CVSS 3.1 bahosi, executive summary, attack walkthrough, proof of access, tuzatish rejasi va cleanup statement bilan yakunlanib, retest o'tkazildi.

QA / sifat nazorati

- 20+ yirik veb-sayt va admin dashboard** uchun funksional, regressiya hamda UI testlari o'tkazildi; topilgan xatoliklar takrorlash qadamlari, kutilgan/haqiqiy natija va skrinshotlar bilan hujjatlashtirildi.
- 90+ reliz (zapusk)** ishga tushirishdan oldin test qilinib tasdiqlandi — relizga chiqqan kritik xatoliklar soni sezilarli kamaydi.
- Test-case'lar tuzildi va yangilab borildi; QA jarayoniga xavfsizlik tekshiruvi (input validatsiya, ruxsatlar, sessiya boshqaruvi) qo'shildi.

MUSTAQIL LOYIHALAR VA TADQIQOT

- HackTheBox, TryHackMe va VulNyx'da **20+ mashina** ekspluatatsiya qilindi (2025 - hozirgacha): Memcached credential leak, file upload bypass, Python module hijacking, LFI + log poisoning, KeePass cracking, GTF0Bins privesc. Yozilgan Python/Bash avtomatlashtirish skriptlari tekshiruv vaqtini ~4 soatdan 90 daqiqagacha qisqartirdi.
- recontool** — attack surface recon frameworki (Go/Python): host, xizmat va content discovery bitta ish oqimida. **QAForg Academy** — geymifikatsiyalangan QA o'quv platformasi (TypeScript).

SERTIFIKATLAR

Olingan: HAAD Red-0 — Penetration Testing asoslari, 05.05.2026 (HID: 866912I136)

Kurs 100% yakunlangan, imtihon kutilmoqda: HTB Certified Penetration Testing Specialist (CPTS) • HTB Web Exploitation Specialist (SWES) • HTB Certified Defensive Security Analyst (CDSA)

Tayyorgarlik jarayonida: CompTIA Security+

TA'LIM

Kiberxavfsizlik bo'yicha professional dastur | *Sentabr 2025 - Iyun 2026*

HAAD Training Center

Tarmoq va veb-ilovalar xavfsizligi, penetration testing, SIEM, Active Directory, incident response.

TEXNIK KO'NIKMALAR

Pentest vositalari	Burp Suite, nmap, ffuf, Gobuster, Metasploit, Hydra, John the Ripper, curl/jq, PyJWT, openssl, Wireshark, LinPEAS
Texnikalar	Veb-ilova va API xavfsizligi (SQLi, XSS, IDOR, auth/OTP bypass, JWT hujumlari, SSRF, LFI, fayl-oshkorlik), privesc (SUID, sudo, cron), reverse shell, Active Directory asoslari
Metodologiyalar	PTES, OWASP WSTG, OWASP Top 10, MITRE ATT&CK, CVSS 3.1, pentest hisobot yozish
Infratuzilma	AWS EC2, Docker/konteyner izolyatsiyasi, nginx, GCP IAM / service-account audit, Linux
QA / Testlash	Funksional, regressiya va UI testlash, test-case yozish, bug reporting, reliz oldi tekshiruvi
Dasturlash	Python, Bash, Go, avtomatlashtirish skriptlari
Tillar	O'zbek (ona tili), Ingliz (B1+ darajada)